



SECURITY ANALYSIS AND REDESIGN OF CLOUDCORP'S CLOUD ARCHITECTURE

From Public Bucket to Defense in Depth

INCIDENT

AWS · MULTI-AZ

REDESIGNED

GDPR

THE INCIDENT

Public S3 bucket exposed all customer data – no logging to detect it.

THE REDESIGN

Multi-AZ AWS with defense in depth across every layer.

THE OUTCOME

~\$335/month for a verified, production-grade environment handling personal data safely.

```
// Original misconfiguration (incident root cause)
resource "aws_s3_bucket_acl" "data" {
  bucket = aws_s3_bucket.data.id
  acl = "public-read"
}

# Bucket exposed to internet
# .....

// Redesign – defense in depth
resource "aws_s3_bucket_public_access_block" "data" {
  bucket = aws_s3_bucket.data.id
  block_public_acls = true
  block_public_policy = true
  ignore_public_acls = true
  restrict_public_buckets = true
}

# Account-level block enforced
```

PRESENTED BY

Daniel Hållbro

Frans Schartaus Handelsinstitut · 2026-05-15

CS25 IT- AND CYBERSECURITY SPECIALIST

CLOUD & VIRTUAL SERVICE SECURITY (30P)

A breach on every layer

CONFIDENTIALITY · INTEGRITY · AVAILABILITY — ALL AFFECTED

ROOT CAUSE

PUBLIC S3 BUCKET

ATTACK COMPLEXITY

A WEB BROWSER & THE RIGHT URL

01 NETWORK

Single public subnet — backend & data exposed alongside the frontend. SSH and HTTP open to 0.0.0.0/0.

02 STORAGE

S3 bucket with Public Read, no encryption, no policy. This is how it started.

03 IAM

A single IAM user with full S3 access. No roles, no MFA — one phished credential ends everything.

04 LOGGING

No CloudTrail, no CloudWatch. No way to know what was taken or whether a backdoor was left behind.

05 RESILIENCE

Single EC2, single AZ, no Auto Scaling — any disruption takes the whole service down with it.

cloudcorp-data · POST-INCIDENT

```
# defaults left in place — never reviewed
resource "aws_s3_bucket_acl" "data" {
  bucket = aws_s3_bucket.data.id
  acl = "public-read"
}

→ reachable on the open web

# no forensics possible
data "aws_cloudtrail_event_data_store" "main" {}
  ▫ no trail enabled in this region
  ▫ what was taken? unknown.

# GDPR Art. 33 · 72-hour notification
  ▫ scope & affected subjects undetermined
```

STATUS · CONFIRMED EXFILTRATION

CIA · ALL THREE

CONFIDENTIALITY

Public-read + no encryption + one IAM user guarding everything. Anyone with the URL could download.

INTEGRITY

Full write access, no versioning. Objects could have been replaced or modified silently. EC2 may also be tampered.

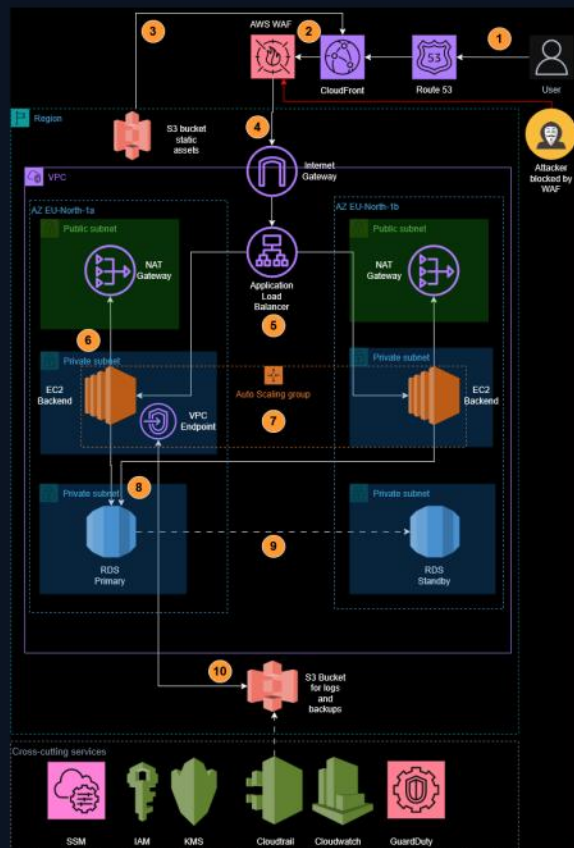
AVAILABILITY

Single EC2, no LB, no Multi-AZ. Any disruption — attack, op error, AZ incident — takes the entire service down.

Multi-AZ AWS, defense in depth

VPC · 2 AZ · 6 SUBNETS · EDGE → ALB → EC2 → RDS

CLOUDCORP · AWS REFERENCE ARCHITECTURE



LEGEND

- User → Route 53**
DNS · alias record points to CloudFront.
- CloudFront + WAF**
CDN · TLS termination · Shield Std.
WAF blocks SQLi / XSS / known IPs.
- S3 · Static assets**
Private bucket · Origin Access Control.
- Internet Gateway**
Dynamic traffic enters the VPC after edge filtering.
- Application Load Balancer**
TLS termination · health checks · cross-AZ target group.
- EC2 Backend**
Private app subnets · no SSH, no public IPs · access via SSM.
- Auto Scaling Group**
2-4 instances across AZs · clean AMI on replacement.
- RDS Primary**
Private data subnet · port 3306 from EC2 SG only.
- RDS Standby**
Synchronous replica · automatic failover in 60-120s.
- S3 · Logs & backups**
Reached via VPC Gateway Endpoint · KMS · MFA Delete.

CROSS-CUTTING SERVICES

SSM (no SSH access) · IAM (least-privilege roles) · KMS (encryption keys) · CloudTrail (API audit log) · CloudWatch (metrics + alarms) · GuardDuty (threat detection)

EDGE → ALB → EC2 → RDS — every layer assumes the previous one failed

~\$335/MO · GDPR

Defense in depth at \$335/month

USD 335.14/MO · SEK ~3 520 KR · FREE-TIER SERVICES EXCLUDED

MONTHLY AWS COST BY CATEGORY



FINAL COST SUMMARY

SERVICE	USD/MO	SEK ~/MO
Route 53	\$0.90	~10 kr
CloudFront	\$24.00	~255 kr
AWS WAF	\$20.00	~210 kr
ALB	\$26.91	~285 kr
EC2 + EBS	\$64.41	~680 kr
NAT Gateway (x2)	\$68.08	~720 kr
RDS MySQL Multi-AZ	\$63.89	~675 kr
S3 (main bucket + CRR + static assets)	\$18.42	~195 kr
CloudTrail	\$2.75	~30 kr
CloudWatch	\$19.54	~205 kr
GuardDuty	\$18.65	~200 kr
KMS	\$7.60	~80 kr
Free services (Budgets, VPC Endpoints, IAM, SSM, ACM, ASG)	\$0	0 kr
TOTAL	\$335.14	~3 520 kr

ANNUAL COST · ~\$4 022 USD ≈ 42 200 SEK

~70 % OF SPEND IS COMPUTE, EDGE & NETWORKING – THE PRICE OF MULTI-AZ RESILIENCE

\$335/MO

Security decisions and remaining risks

WHY THESE CHOICES · WHAT WE KNOW IS LEFT

KEY SECURITY DECISIONS

DECISION

MOTIVATION

Private subnets

Backend and database have no public IP addresses – unreachable from the internet regardless of security group.

Multi-AZ

The incident proved single-AZ = single point of failure. RDS failover in 60-120s, EC2 replaced automatically via ASG.

SSM Session Manager

Port 22 does not exist. No SSH key to lose, phish, or forget to rotate.

CloudFront + WAF

SQLi/XSS filtered at the edge before traffic ever reaches the VPC.

S3 public access block

The same mistake that caused the incident is now blocked at account level – impossible to accidentally repeat.

REMAINING RISKS

RISK

STATUS

Single region

Conscious trade-off – multi-region increases cost 2-3x, not justified now.

NAT Gateway × 2

Most expensive single item (\$68/mo) but required for private subnet outbound.

CloudWatch not tuned

Requires real traffic before correct threshold values can be established.

Untrained personnel

Architecture is secure on paper – misconfigurations happen when the team lacks AWS experience and certifications.

No IaC / Compliance as Code

Infrastructure is manually provisioned. No pull requests to catch misconfigurations before they reach production.

Questions & GitHub

THANK YOU FOR LISTENING · FULL PROJECT AVAILABLE BELOW

Questions?



DanielHallbro / AWS_Cloud_Security_Project

github.com/DanielHallbro/AWS_Cloud_Security_Project

CLOUD & VIRTUAL SERVICE SECURITY · 2026 · INDIVIDUAL PROJECT

WHAT'S IN THE REPO

- Full security analysis report
- CloudCorp architecture diagram
- AWS cost breakdown
- Terraform config examples
- This presentation

SCAN TO VISIT REPO

